

[CONFIDENTIAL]

Security Incident Report — March 2026

(CONFIDENTIAL)

Author: CISO Office / Security Team

Department: Confidential

Last Updated: 2026-03-28

Classification: confidential

On 2026-03-14, NovaTech's Security Operations Centre detected anomalous read patterns against the Qdrant production cluster. Investigation confirmed that a misconfigured network policy allowed a compromised staging pod to reach the production Qdrant API without authentication. An estimated 4 200 document chunks were read by the attacker before containment at 03:47 UTC. No user PII was accessed. All affected customers (8 enterprise accounts) were notified within 72 hours per contractual obligation.

1. Incident Timeline

Timestamp (UTC)	Event
2026-03-14 01:22	First anomalous Qdrant query detected in CloudWatch
2026-03-14 02:15	SOC analyst escalates to on-call security engineer
2026-03-14 03:47	Qdrant API key rotated; staging-to-prod network path blocked
2026-03-14 04:30	Containment confirmed; forensic snapshot taken
2026-03-14 10:00	CEO and Board notified via encrypted channel
2026-03-16 09:00	Customer notification emails sent (8 enterprise accounts)
2026-03-28 17:00	Root cause analysis complete; this report published

2. Root Cause

A Kubernetes NetworkPolicy update deployed on 2026-03-12 inadvertently removed the namespace isolation between *staging* and *retriever* namespaces. The staging environment had an unpatched container (CVE-2024-8819, HIGH severity) that was exploited via a publicly known container escape technique. The attacker pivoted to the production Qdrant cluster which, at the time, had API key authentication disabled for 'testing purposes' — a policy violation by an unnamed engineer.

3. Remediation & Controls

- NetworkPolicy restored and locked; changes now require dual approval via PR.
- Qdrant API key authentication re-enabled; key stored in AWS Secrets Manager.
- mTLS enforced between all pods and Qdrant (cert-manager, 90-day rotation).
- Trivy scan added to CI — HIGH/CRITICAL CVEs block all staging deploys.
- SOC 2 Type II scope expanded to include vector database access controls.
- Security awareness training mandated for all engineers by 2026-04-30.

4. Financial & Legal Impact

Estimated incident cost: \$340 000 (forensics: \$80K, legal: \$120K, customer credits: \$140K). Two enterprise accounts requested SLA credits totalling \$85 000. NovaTech's cyber insurance policy (AIG, \$5M limit) covers forensics and legal costs; claim filed 2026-03-20.